信息安全测评与风险评估

7.4.1 工控系统架构认知

授课教师：张玉



目录

CONTENTS

01 案例导入——“震网病毒：摧毁核设施的代码”

02 学习目标

03 什么是工业控制系统（ICS）？

04 三大核心工控系统类型

案例导入——“震网病毒：摧毁核设施的代码”

2010年，伊朗核设施上千台离心机在监控“一切正常”时自毁。

震网（Stuxnet）：第一个专门摧毁实体设施的病毒，攻击对象是与互联网物理隔离的核设施。

病毒先感染外网电脑，经U盘“摆渡”进入与互联网隔离的内网，逐层渗透后驻留在控制层PLC，悄悄修改离心机转速，同时向监控层回传“一切正常”的假数据——操作员看着正常屏幕，上千台离心机却在异常运转中报废。

问题：

- 物理隔离都没能拦住的攻击，究竟钻了架构上的哪一道缝隙？

敲黑板：

工控安全关乎国计民生——电力、石油、交通、供水，任何环节出问题，都可能造成严重的社会后果。

维度	内容
攻击目标	伊朗纳坦兹核设施
攻击方式	攻击西门子S7-300/400系列PLC
攻击效果	修改离心机转速，导致物理损坏
隐蔽性	向监控系统回传伪造的正常数据
规模	感染全球超过20万个网络节点
历史地位	首个被确认的针对工业控制系统网络战武器

学习目标

通过本课学习，你将能够：

01 **理解：**工业控制系统（ICS）的基本概念、主要类型和核心组件

02 **掌握：**工业控制系统的五层架构模型

03 **理解：**工控系统与企业IT系统的根本区别

04 **识别：**工控系统的核心安全脆弱点

05 **为：**后续工控安全扩展要求测评学习奠定基础

什么是工业控制系统（ICS）？

1 GB/T 32919-2016 定义

工业控制系统（Industrial Control System，ICS）是一个通用术语，包括多种工业生产中使用的控制系统，包括数据采集与监视控制系统（Supervisory Control And Data Acquisition，SCADA）、分布式控制系统（Distributed Control System，DCS）和其他较小的控制系统，如可编程逻辑控制器（Programmable Logic Controller，PLC）。

2 通俗理解

- 工控系统 = 工业生产的**“大脑”**和**“神经系统”**
- 控制工业生产过程——从石油炼化到电力输送等。

行业	典型应用
电力	发电厂控制、电网调度
石油化工	炼油控制、管道监控
水处理	自来水厂、污水处理厂
交通	地铁信号控制、交通调度
制造业	生产线自动化控制
国防	武器装备控制

三大核心工控系统类型

记住三个缩写：SCADA、DCS、PLC——它们是工控系统的“三驾马车”。

SCADA

（监控和数据采集系统）

☑定位：上层监控调度软件体系

☑擅长：远距离、大范围的数据采集、监视、下发指令，一般不做复杂的底层闭环控制

典型场景：长距离管线、城市供水、油气管道、电网远动、多个站点集中监控。

☑特点：

- SCADA 本身通常不直接控制设备；控制是靠下面的 PLC/RTU 完成；
- 重点：收数据、画面展示、报警、历史记录、远程下发设定值；
- 可以对接很多不同品牌、不同地点的 PLC/RTU；
- 重点在“监视 + 采集”，不是成套控制硬件。

DCS

（分布式控制系统）

☑定位：成套的、一体化的大型控制系统

☑擅长：连续工艺、模拟量、闭环调节（温度、压力、液位、流量持续稳定控制）

典型场景：炼油、化工、电厂、制药、大型冶金。

☑特点：

- 控制分散在各个现场控制站，操作、显示集中在中控室；
- 天生重视冗余、安全、联锁，可靠性等级极高；
- 整套软硬件同厂商配套；
- DCS 里面的现场控制站，功能上很像 PLC，但架构是成套一体的。

PLC

（可编程逻辑控制器）

☑定位：现场独立控制单元（控制器硬件）

☑擅长：开关量、逻辑、顺序控制

典型场景：流水线、包装机、电梯、单台设备、泵站、风机、阀门启停。

☑特点：

- 单台 PLC 负责一小套设备；
- 编程灵活（梯形图等）；
- 可以单独运行，脱离上位机也能自主控制；
- 可以接入 DCS 或者 SCADA 系统。

– PLC（可编程逻辑控制器）——工控系统的“执行器”

PLC是工控系统中最核心、最常见、也是最容易成为攻击目标的设备。

PLC的组成及安全关注点

组成部分	功能	安全关注点
CPU	逻辑与数学运算	固件安全
存储器	存储程序与数据	程序篡改风险
输入/输出模块	接收/输出信号	I/O接口安全
通信接口	与其他设备通信	协议安全
电源	提供电力	供电安全



素材4：PLC基础知识快速参考卡.docx

PLC的工作原理：扫描周期

循环周期通常为10-100ms

1

输入采样

读取输入信号
（传感器/按钮等）

2

程序执行

按用户程序逻辑进行运算

3

输出刷新

运算结果输出
（电机/阀门等）

SCADA与DCS的区别

维度	SCADA	DCS
地理分布	广域（跨城市、跨省）	局域（工厂内部）
通信方式	无线、卫星、公网	有线工业以太网、现场总线
控制对象	分散的远程设备	集中的过程设备
实时性要求	**秒级~分钟级**	**毫秒级**
典型应用	电网调度、输油管道	化工厂、炼油厂
通信协议	IEC 60870-5、DNP3	Modbus TCP、PROFINET

工控系统的五层架构模型

依据IEC 62264-1标准，工控系统从上到下分为5个层级。



五层架构各层详解

素材1：工控系统架构认知记录表.do

层次	层级名称	核心设备/系统	核心功能	直观比喻
5	企业资源层	ERP系统	企业决策、供应链管理	类似于企业OA/财务系统
4	生产管理层	MES系统	生产调度、工艺管理	生产指挥中心
3	过程监控层	HMI、SCADA服务器	数据采集、人机交互	生产仪表盘
2	现场控制层	PLC、DCS控制器	逻辑控制、实时响应	生产大脑
1	现场设备层	传感器、执行器	感知物理世界、执行动作	生产手和眼